

ZENITH ORBITAL SYSTEMS

Server Vulnerability Management Policy

Effective: March 28, 2026 | Next Review: March 2027 | Version 1.0

Prepared by: Noe Valencia, PSSE

1. Purpose

This Vulnerability Management Policy establishes a comprehensive, risk-based framework for identifying, prioritizing, remediating, and tracking vulnerabilities across all Zenith Orbital Systems (ZOS) server infrastructure, endpoints, and network devices. Unpatched vulnerabilities are consistently among the most preventable and most exploited attack vectors. The 2025 Verizon DBIR identified vulnerability exploitation as the initial access vector in 20% of all breaches analyzed, and the CISA KEV catalog grew by 245 confirmed-exploited vulnerabilities in 2025 alone.

For ZOS, which operates ground station infrastructure supporting orbital asset command and control, a successful exploitation of an unpatched vulnerability could result in loss of satellite command capability. This policy is built around that operational reality.

2. Scope

This policy applies to all ZOS personnel who administer, maintain, or interact with any in-scope system. In-scope systems include:

- All ZOS server infrastructure (physical and virtual) including domain controllers, file servers, application servers, VoIP servers, and backup systems
- All ZOS endpoint devices including workstations, laptops, and mobile devices enrolled in ZOS management
- All ZOS network devices including firewalls, switches, routers, and wireless access points
- All ZOS cloud-hosted systems and virtual machines
- All third-party systems with network connectivity to ZOS infrastructure

Compliance with this policy is mandatory for all in-scope individuals. Deviations require written approval per Section 12.

3. Principle Statement

Vulnerability management at ZOS operates on the principle of continuous, risk-based prioritization. Not all vulnerabilities pose equal risk. CISA's Known Exploited Vulnerabilities catalog, CVSS scoring, and ZOS-specific operational context together determine remediation priority. Speed matters: the median time from vulnerability disclosure to exploitation in the wild dropped to under 5 days in 2025. ZOS remediation SLAs are calibrated to that reality.

4. Senior Management Commitment

ZOS senior leadership is fully committed to the implementation and enforcement of this Vulnerability Management Policy. We recognize that unpatched server and system vulnerabilities are among the most preventable and consistently exploited entry points for ransomware, data breaches, and unauthorized access. We commit to providing the scanning tools, remediation resources, and organizational authority required to manage vulnerabilities effectively.

Signed: _____ **Date:** _____
Chief Information Security Officer / Senior IT Leadership, Zenith Orbital Systems

5. Roles and Responsibilities

Role	Primary Responsibilities
IT Security Manager	Policy owner; oversees VM system operation; sets remediation SLAs; approves exceptions; escalates unresolved critical vulnerabilities to leadership
Systems Administrator	Deploys and maintains scanning agents; remediates identified vulnerabilities per SLA; implements configuration fixes for CCE findings; coordinates with change management
Security Analyst	Reviews scan results; validates prioritization; investigates anomalies; produces technical and business reporting; tracks open vulnerability aging
IT Manager	Receives business unit vulnerability reports; ensures remediation resources are allocated; approves emergency patching outside normal change windows
Business Leadership	Receives executive vulnerability posture reports; provides organizational authority for resource allocation to address critical unresolved vulnerabilities
All Staff	Must not interfere with vulnerability scanning agents; must report suspected system compromises immediately to the IT Security Manager

6. Policy Safeguards

6.1 Vulnerability Management System and Scanning

Control ID	Requirement
VUL-01	Deploy an enterprise-grade vulnerability management system (Qualys VMDR) with authenticated scanning agents on all in-scope systems. Unauthenticated scanning alone is insufficient and does not satisfy this control.
VUL-02	All in-scope systems must be enrolled in the VM system. Coverage must be verified monthly. Any newly deployed system must be enrolled within 5 business days of deployment.
VUL-03	Vulnerability scans must be performed at minimum weekly for all in-scope systems. Systems identified as high-risk or previously compromised may be scanned more frequently at the IT Security Manager's direction.
VUL-04	All scans must be authenticated using valid credentials with sufficient privilege to perform a complete system audit. Scan credentials must be managed within the approved PAM system (CyberArk) and rotated per the password policy.
VUL-05	Scan results must be retained for a minimum of 12 months to support trend analysis, compliance reporting, and forensic investigations.

6.2 Vulnerability Prioritization and Remediation SLAs

Control ID	Requirement
VUL-06	All identified vulnerabilities must be prioritized using CVSS score and CISA KEV catalog status. Remediation SLAs are defined as follows: Critical (CVSS 9.0 to 10.0 or KEV listed) 15 days for internet-facing systems and 30 days for internal systems. High (CVSS 7.0 to 8.9) 30 days. Medium (CVSS 4.0 to 6.9) 90 days. Low (CVSS below 4.0) 180 days or next scheduled maintenance.
VUL-07	The VM system must compare consecutive scan results to track remediation progress over time, identifying newly discovered vulnerabilities, successfully remediated items, and vulnerabilities that have aged beyond their remediation SLA.

VUL-08	The VM system must maintain a continuously updated register of all open vulnerabilities including their severity, affected system, assigned owner, discovery date, SLA deadline, and current remediation status.
---------------	--

6.3 Exception Tracking and Reporting

Control ID	Requirement
VUL-09	The VM system must track all approved vulnerability exceptions including the CVE or CCE identifier, affected system, business justification, compensating controls in place, approving authority, and exception expiration date. Exceptions must be reviewed at minimum quarterly.
VUL-10	Technical vulnerability reports for Security Analysts and Systems Administrators must be generated at minimum weekly and include newly discovered vulnerabilities, SLA status for open items, scan coverage metrics, and remediation trend data.
VUL-11	Business unit vulnerability reports summarizing open vulnerabilities affecting systems supporting their functions, expressed in business impact terms, must be generated at minimum monthly.
VUL-12	Executive vulnerability posture reports for ZOS leadership must include overall vulnerability trend metrics, SLA compliance rates, critical open vulnerability counts, and risk posture summary expressed in business risk terms. Generated at minimum monthly.

7. Remediation SLA Summary

Severity / CVSS Range	Internet-Facing SLA / Internal System SLA
Critical or KEV Listed (CVSS 9.0 to 10.0)	15 days / 30 days
High (CVSS 7.0 to 8.9)	30 days / 30 days
Medium (CVSS 4.0 to 6.9)	90 days / 90 days

Low (CVSS below 4.0)	180 days / Next maintenance window
-----------------------------	------------------------------------

Vulnerabilities listed in the CISA Known Exploited Vulnerabilities (KEV) catalog are treated as Critical regardless of their CVSS score, due to confirmed active exploitation. The IT Security Manager may escalate SLA timeframes for any vulnerability based on active threat intelligence.

8. Penetration Testing

Vulnerability scanning identifies known vulnerabilities based on CVE and CCE databases. Penetration testing goes further by attempting to chain and exploit vulnerabilities to determine actual exploitability and impact in the specific ZOS environment. ZOS requires both: continuous scanning for known vulnerabilities and periodic penetration testing to validate that the vulnerability management program is actually reducing risk.

- Annual penetration testing by a qualified third-party firm is required at minimum.
- The penetration test scope must include ZOS external attack surface, internal network segmentation, wireless networks, and social engineering components.
- All penetration test findings must be remediated per the standard SLA timeframes, with critical findings tracked by the IT Security Manager to completion.
- Penetration test reports must be retained for a minimum of three years.

9. Legal and Regulatory Obligations

Framework	Relevance to This Policy
NIST SP 800-40 Rev 4	Defines patch management program requirements including scan frequency, remediation SLAs, and exception handling
NIST SP 800-53 Rev 5	SI-2 (Flaw Remediation), RA-5 (Vulnerability Scanning), SI-6 (Security Function Verification)
NIST CSF 2.0	Identify (ID.RA) and Protect (PR.IP) functions: vulnerability assessment and remediation
CIS Controls v8	Control 7 (Continuous Vulnerability Management): scanning, prioritization, remediation, and reporting requirements
CISA Binding Operational Directive 22-01	KEV catalog remediation mandates adopted as industry best practice for prioritization

PCI DSS v4.0	Requirements 6.2, 6.3, 11.3: vulnerability scanning, penetration testing, and remediation SLAs
ISO/IEC 27001:2022	Annex A.8.8 (Management of technical vulnerabilities): scanning, assessment, and remediation requirements

10. Training and Awareness

- Systems Administrators: Annual training on VM system operation, authenticated scan configuration, CVE and CCE remediation procedures, and emergency patching protocols.
- Security Analysts: Ongoing training on vulnerability prioritization frameworks including KEV catalog and EPSS scoring, vulnerability report generation, and trend analysis.
- Business Unit Staff and Leadership: Annual training on interpreting vulnerability posture reports and their responsibilities in supporting timely remediation.

11. Compliance Measurement

Activity	Controls Assessed / Frequency
Full authenticated vulnerability scan	VUL-01 through VUL-05 / Weekly
Scan coverage verification	VUL-01, VUL-02 / Monthly
Remediation SLA compliance review	VUL-06, VUL-07, VUL-08 / Weekly
Exception register review	VUL-09 / Quarterly
Annual penetration test	All controls validation / Annual
Executive posture report review	VUL-12 / Monthly

12. Exception Management and Policy Sanctions

All exceptions to remediation SLAs must be submitted in writing to the IT Security Manager with documented business justification, proposed compensating controls, and maximum 90-day duration. Critical and KEV-listed vulnerability exceptions require additional IT leadership approval.

Non-compliance sanctions follow the same structure as the Password Protection Policy, ranging from formal written warning for minor violations to termination and law enforcement referral for willful violations or criminal activity.

13. Continual Improvement

This policy is reviewed at minimum annually. Earlier review is triggered by: a security incident involving an unpatched vulnerability or configuration weakness; addition of a new system category or major infrastructure change; material updates to CISA KEV catalog priorities, NIST guidance, or CIS Controls; changes to applicable regulatory requirements; or findings from penetration testing identifying gaps in this policy's controls.

14. Sources and References

- SANS/CRF Vulnerability Management Policy Template (Feb 2026). <https://www.sans.org/information-security-policy/vulnerability-management-policy>
- CIS Controls v8, Control 7. <https://www.cisecurity.org/controls/v8>
- NIST SP 800-40 Rev 4. <https://csrc.nist.gov/publications/detail/sp/800-40/rev-4/final>
- NIST SP 800-53 Rev 5. <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>
- CISA KEV Catalog. <https://www.cisa.gov/known-exploited-vulnerabilities-catalog>
- CISA Binding Operational Directive 22-01. <https://www.cisa.gov/binding-operational-directive-22-01>
- PCI DSS v4.0. https://www.pcisecuritystandards.org/document_library/